

NOM : ALIAWY MFAM SAKER RICHLAND

Compte rendu du TP1-4 – Analyse de sécurité d’une machine Windows

Environnement :

- Machine cible : Windows [version] – IP 192.168.56.20
- Machine attaquante : Kali Linux – IP 192.168.56.x
- Outil principal : Nmap

1. PREPARATION DE LA MACHINE WINDOWS

Actions réalisées :

- Vérification de l’IP avec ipconfig
- Désactivation temporaire du pare-feu :
netsh advfirewall set allprofiles state off
- (Si RDP testé) Activation du service RDP.

```
C:\Users\aliawy>ipconfig

Configuration IP de Windows

Carte Ethernet Ethernet :

    Suffixe DNS propre à la connexion. . . :
    Adresse IPv6 de liaison locale. . . . : fe80::8883:4cbe:f99c:f3fc%12
    Adresse IPv4. . . . . : 192.168.56.20
    Masque de sous-réseau. . . . . : 255.255.255.0
    Passerelle par défaut. . . . . : 192.168.56.1

C:\Users\aliawy>
```

Capture 1 : ipconfig sur Windows

```
C:\Users\aliawy>ping 192.168.56.30

Envoi d'une requête 'Ping' 192.168.56.30 avec 32 octets de données :
Réponse de 192.168.56.30 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.56.30 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.56.30 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.56.30 : octets=32 temps<1ms TTL=64

Statistiques Ping pour 192.168.56.30:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 0ms, Maximum = 1ms, Moyenne = 0ms

C:\Users\aliawy>
```

```
Microsoft Windows [version 10.0.17134.81]
(c) 2018 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>netsh advfirewall set allprofiles state off
Ok.

C:\Windows\system32>
```

Capture 2 : Désactivation du pare-feu dans PowerShell

2. SCAN DE PORTS (DECOUVERTE INITIALE)

Commande exécutée depuis Kali

```
sudo nmap -sS 192.168.56.20
```

Résultat obtenu (exemple) :

PORT	STATE	SERVICE
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
3389/tcp	open	ms-wbt-server

```

(aliawy@kali)-[~]
└─$ sudo nmap -sS 192.168.56.20
[sudo] password for aliawy:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-16 21:27 CEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0013s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:8B:BE:94 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds

```

Interprétation :

Les ports 135 (RPC), 139/445 (SMB) et 3389 (RDP) sont ouverts. Un attaquant peut tenter d'exploiter ces services pour prendre le contrôle.

3. IDENTIFICATION DES SERVICES ET VERSIONS

```

(aliawy@kali)-[~]
└─$ sudo nmap -sV 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-16 21:33 CEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0010s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
MAC Address: 08:00:27:8B:BE:94 (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.26 seconds

```

Capture 4 : Scan des versions avec -sV

Interprétation :

La version exacte de Windows est identifiée. Cela permet à un attaquant de choisir un exploit adapté.

4. DECOUVERTE DU SYSTEME VIA SCRIPT SMB

```
(aliawy@kali)-[~]
$ nmap --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-16 21:39 CEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0034s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.86 seconds

(aliawy@kali)-[~]
$
```

Interprétation :

L'attaquant récupère le nom de la machine, le groupe de travail et le SP exact – informations clés pour préparer une intrusion ciblée.

5. DETECTION DE VULNERABILITES SMB

```
(aliawy@kali)-[~]
$ nmap --script smb-vuln* -p 445 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-16 21:46 CEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0017s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Host script results:
_smb-vuln-ms10-054: false
_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Nmap done: 1 IP address (1 host up) scanned in 5.60 seconds
```

Interprétation :

Une faille critique permet une exécution de code à distance sans authentification. Cela a été utilisé par WannaCry. La machine peut être compromise immédiatement.

7. SYNTHESE DES RISQUES

7.1 SERVICES CRITIQUES IDENTIFIES

-SAMBA

-RPD

NETBIOS

Port Service Version détectée Vulnérabilité

7.2 RISQUES POUR L'ENTREPRISE

- Piratage complet via EternalBlue → prise de contrôle, installation de ransomware.
- Accès distant mal sécurisé → brute force RDP, vol de données.
- Absence de pare-feu (labo) → en conditions réelles, exposition directe à Internet.

7.3 MESURES DE SECURISATION PROPOSEES

1. Désactiver SMBv1 immédiatement :

Set-SmbServerConfiguration -EnableSMB1Protocol \$false

2- Activer le pare-feu Windows et restreindre SMB/RDP aux IP internes autorisées.

3 -Pour RDP : activer NLA, changer le port (faible efficacité), utiliser un VPN.

4 -Mettre en place des mots de passe forts et une double authentification.

5-Isoler les postes sensibles dans un VLAN.

6-Effectuer des mises à jour de sécurité régulières.

7-Surveiller les logs d'authentification SMB/RDP.

8. CONCLUSION

Ce TP a montré comment un attaquant peut, à partir d'un simple scan Nmap, identifier des services vulnérables sur une machine Windows. La présence de SMB non corrigé rend la cible extrêmement exposée. Les mesures de durcissement proposées doivent être appliquées avant toute mise en production.